

Penetration Testing Report

Target: <https://medirozahospital.com>

Client: Mediroza General Hospital

Engagement Type: Black-Box Penetration Test

Batch: B083C | Week 4

1. Executive Summary

A black-box penetration test was conducted against the simulated Mediroza General Hospital web environment to assess externally accessible infrastructure and determine whether an unauthorized external user could compromise sensitive assets. The engagement was structured around four core milestones, focusing on reconnaissance, authentication security, file encryption protection, and sensitive information exposure.

Testing identified multiple critical vulnerabilities, most notably an unauthenticated SQL injection vulnerability within the patient portal authentication mechanism. This allowed attackers to bypass authentication controls entirely, retrieve confidential patient PDF reports, perform offline password recovery, and ultimately access a publicly exposed database backup containing sensitive employee salary and shareholder data. Immediate remediation is strongly advised to secure authentication gates and purge legacy web assets.

2. Scope and Methodology

- **Target:** <https://medirozahospital.com> (IP: 199.188.201.16)
- **Approach:** Black-box assessment simulating an external attacker with no prior knowledge of internal application architecture or source code.
- **Tools Utilized:** nslookup, WhatWeb, WAFWOOF, Nmap, pdf2john, Hashcat, qpdf, exiftool, web browser developer tools, and manual HTTP interception.
- **Limitations:** Rules of engagement explicitly prohibited Denial-of-Service (DoS) attacks and social engineering.

3. Reconnaissance & Discovery

- **Domain Resolution & Port Scanning:** Initial enumeration via Nmap identified open services including FTP (port 21), SSH, HTTP (port 80), HTTPS (port 443), and various mail daemons.
- **Robot File Analysis:** Inspecting <https://medirozahospital.com/robots.txt> revealed sensitive unindexed directories intended to be hidden from search engines.

None

Disallow: /patient/

Disallow: /staff/

Disallow: /old/

These entry points provided the primary structural roadmap for the subsequent exploitation phases.

4. Findings and Proof of Exploitation

Finding 1: SQL Injection in Patient Portal Authentication

- **Location:** /patient/login.php
- **Severity:** **Critical**
- **Description:** User-supplied input in the username field was improperly concatenated directly into backend database queries without parameterization, returning verbose MySQL syntax errors and permitting authentication bypass via payload manipulation (e.g., admin' -- -).
- **Evidence:**

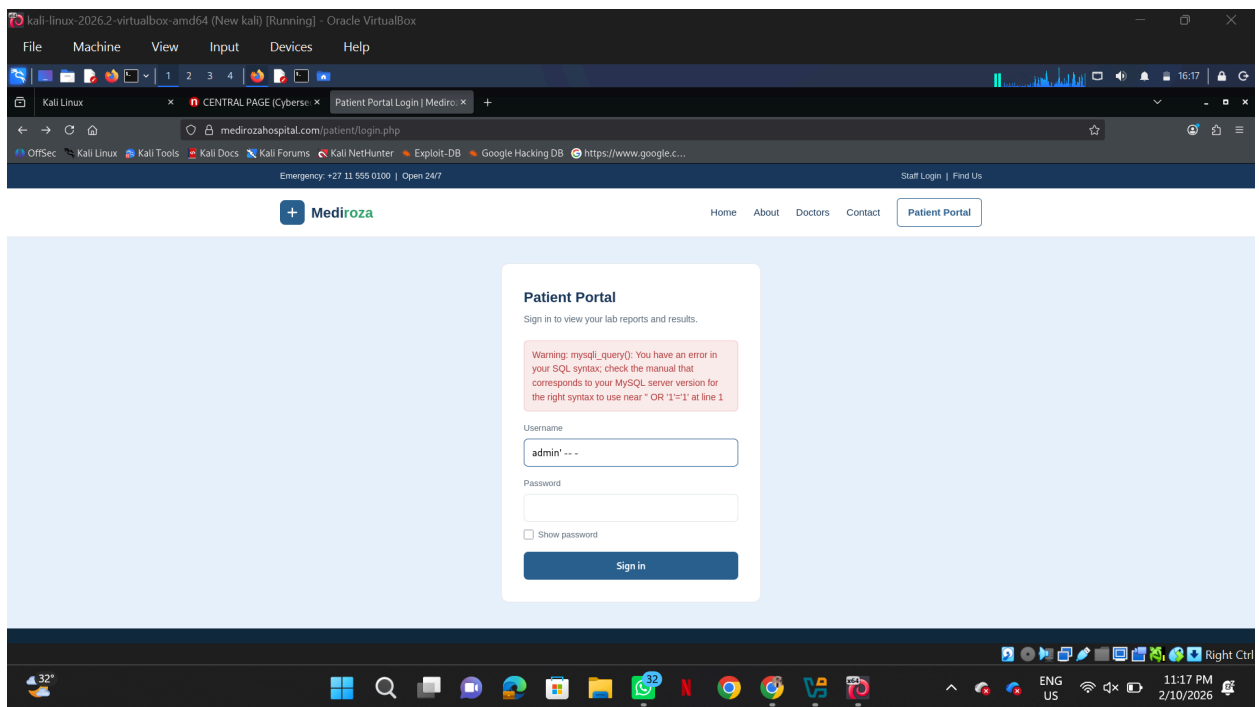


Figure: Patient Portal MySQL Error

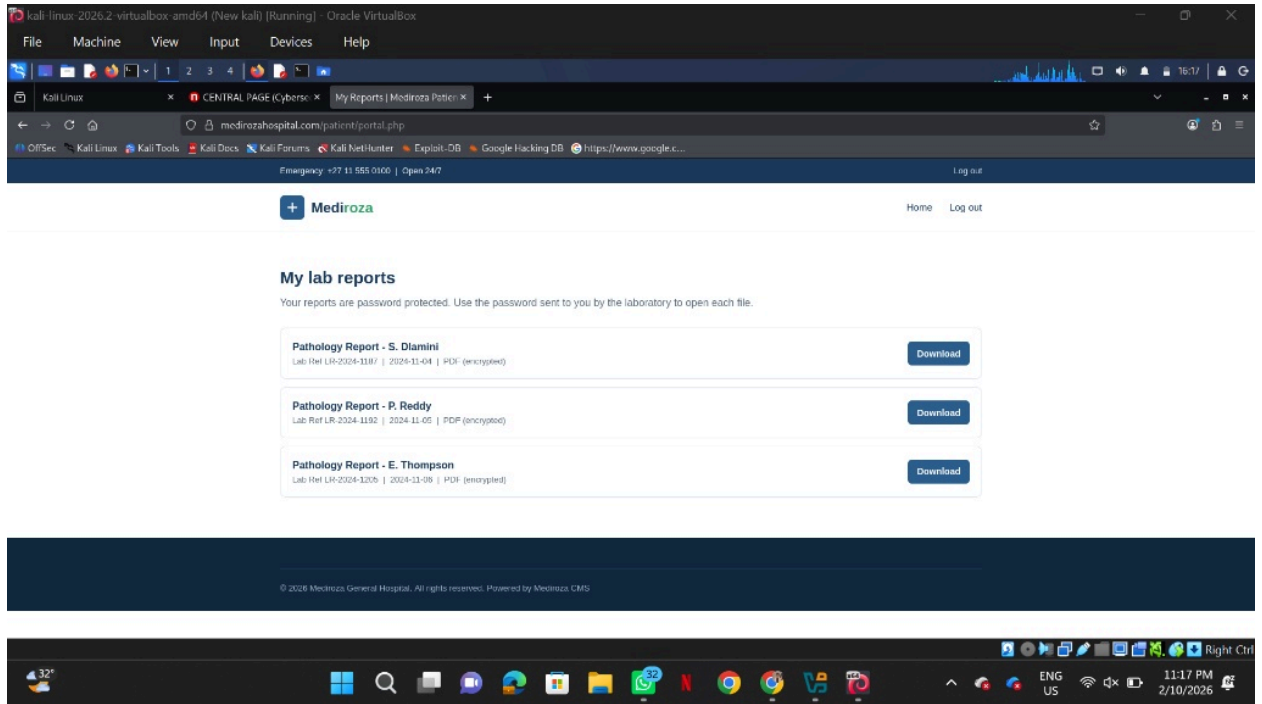


Figure: Successful Bypass Dashboard

Finding 2: Insufficient Password Protection of Patient Reports

- **Location:** Downloaded patient report files (patient_report_*.pdf)
- **Severity: High**
- **Description:** Patient pathology files were protected using weak document-level passwords susceptible to dictionary and brute-force attacks once extracted using tools like pdf2john and cracked using expanded wordlists.
- **Evidence:**

Kali Linux

File Machine View Input Devices Help

1 2 3 4

Kali Linux My Reports | Mediroza Pathology Report - S.I. patient_report_3.p Password Cracking Password Cracker Hash Calculator - I. X

file:///home/kali/Downloads/patient_report_2.pdf

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB https://www.google.c...

1 of 1

Automatic Zoom

Mediroza General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT **CONFIDENTIAL**

Patient Name: Priya Reddy Report Date: 2024-11-05
Patient ID: MG-P-10244 Referring Dr: Dr. Johan van der Merwe
Date of Birth: 1991-02-28 Specimen: Serum
Gender: Female Lab Ref No: LR-2024-1192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

32°

Windows Search Taskbar Icons

ENG US 11:31 PM 2/10/2026

Kali Linux

File Machine View Input Devices Help

1 new message My Reports | Mediroza Pathology Report - S.I. patient_report_3.p patient_report_2.p Password Cracking Password Cracker Hash Calculator - I. X

networkwalks.com/hash-calculator/

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB https://www.google.c...

Wazuh

Generate MD5, SHA-1, SHA-256, SHA-384, SHA-512, or extract a crackable hash from a password-protected PDF

Text File PDF

Click to choose a PDF, or drop one here
Nothing is uploaded, the PDF is parsed locally

patient_report_2.pdf | 9.5 KB

This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).

PDF Hash

spdf52*3*120*4204967292*1*32*3166346338372323635643762646436383466373730
326563366636264616463*32*39f4e6b8aedf12344c340ffb3f8995528bf4e5e4e75b
a4164804e56ffffa8108*32*408b37bcf12a873d7f2840f3c1b917a023961ded4c8164d
38e46e9655e66775

Copy Download

Revision: R3 Version: V2 Key length: 128 bit

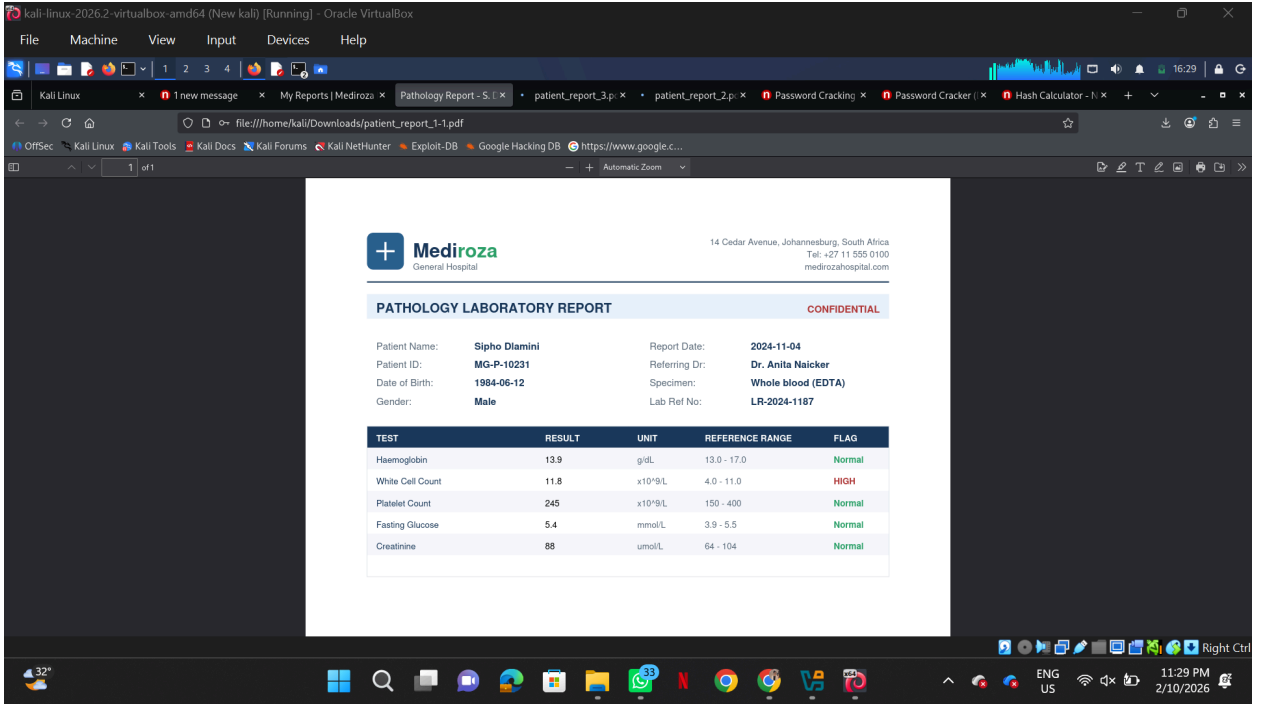
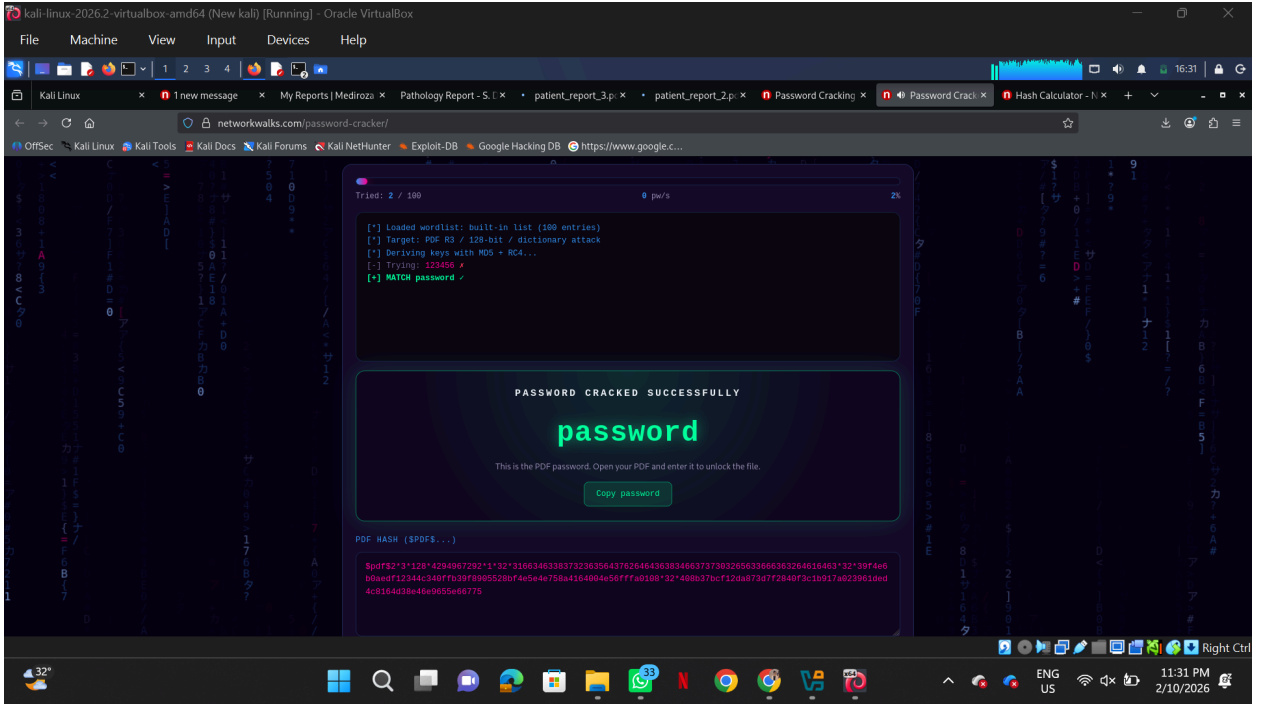
Upload a PDF to check if it is password protected and extract a crackable hash.

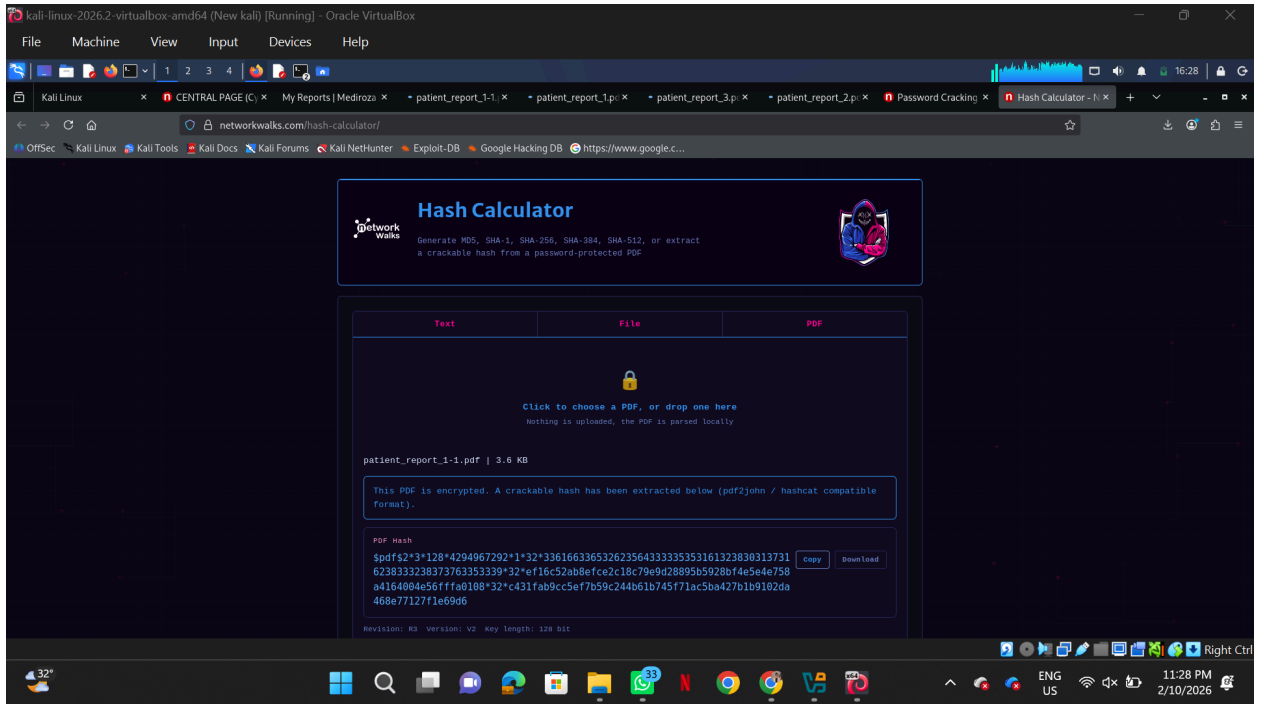
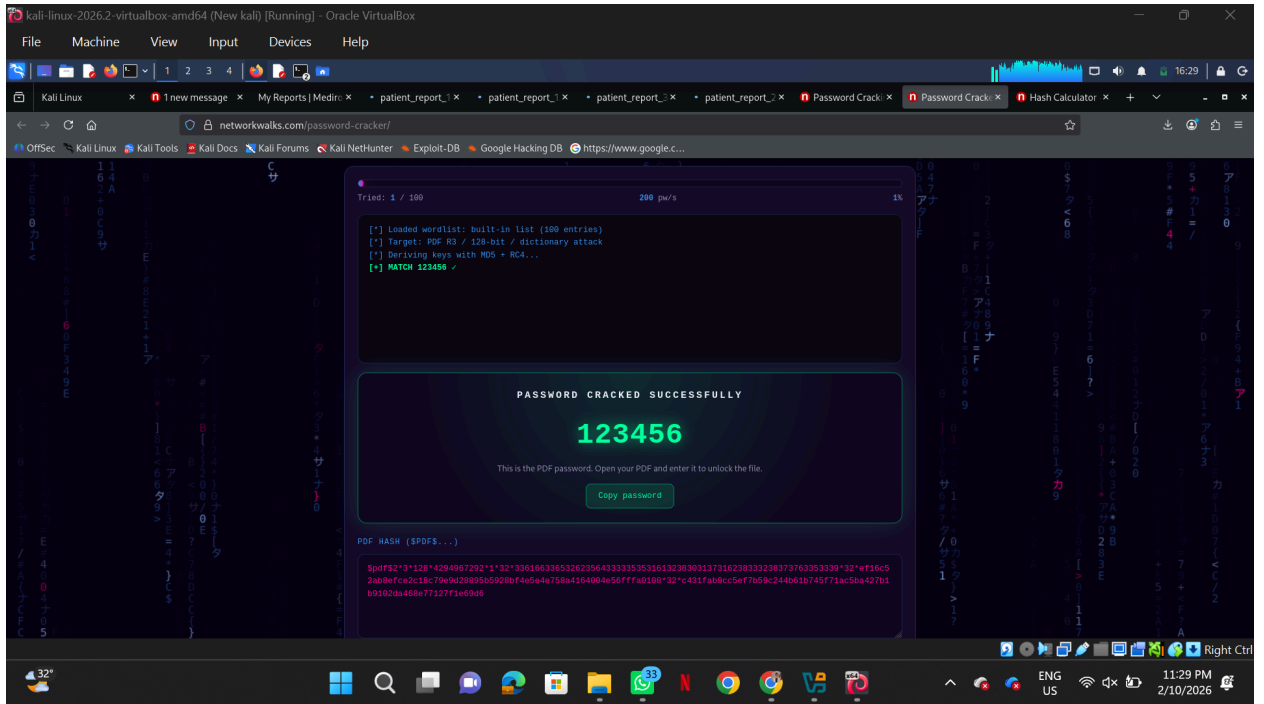
Free tool by Networkwalks Academy | Cybersecurity & Ethical Hacking with AI

32°

Windows Search Taskbar Icons

ENG US 11:31 PM 2/10/2026





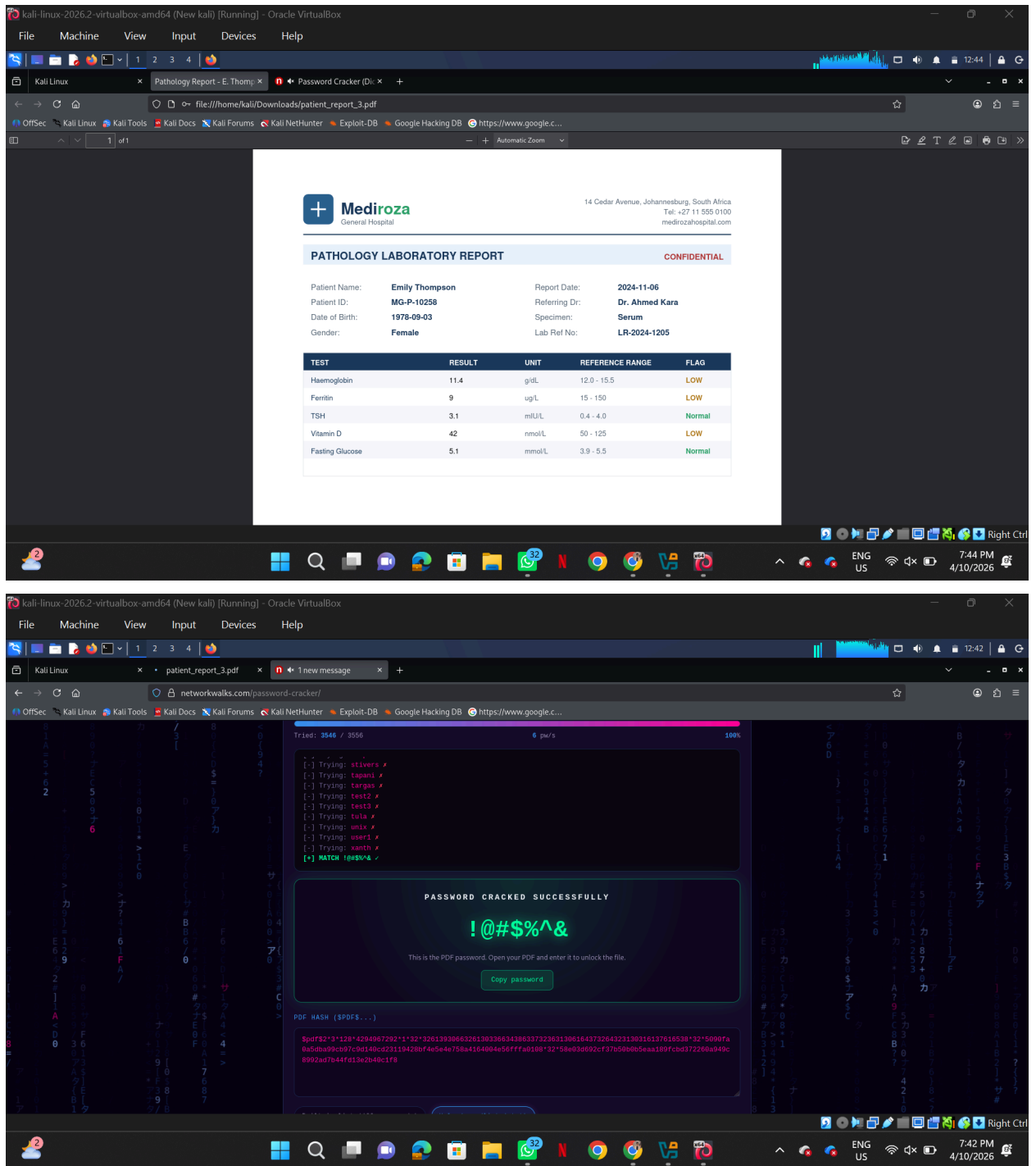


Figure: PDF Hash Extraction and Password Recovery Results

Finding 3: Sensitive Metadata Exposure in PDF Files

- **Location:** patient_report_3.pdf
- **Severity: Medium**

- **Description:** Metadata analysis using exiftool revealed internal author accounts (j.malik) and developer comments pointing to backup migration paths (DB backup moved to /old before site migration).
- **Evidence:**

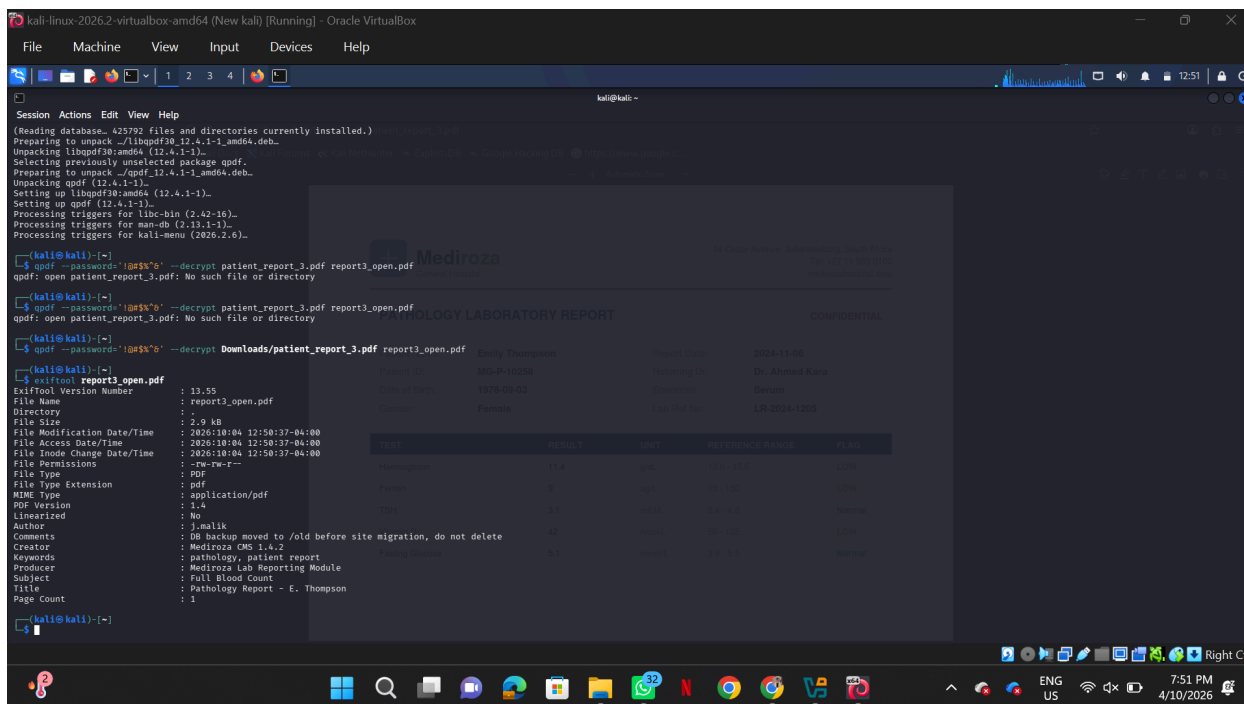


Figure: Exiftool Metadata Output Displaying IT Notes

Finding 4: Publicly Accessible Database Backup & Directory Listing

- **Location:** /old/ directory (/old/mediroza_db_backup_2019.sql)
- **Severity:** **Critical**
- **Description:** The legacy directory was explicitly disclosed via robots.txt and permitted public directory browsing, exposing an unauthenticated raw SQL database dump containing confidential staff salaries and shareholder records.
- **Evidence:**

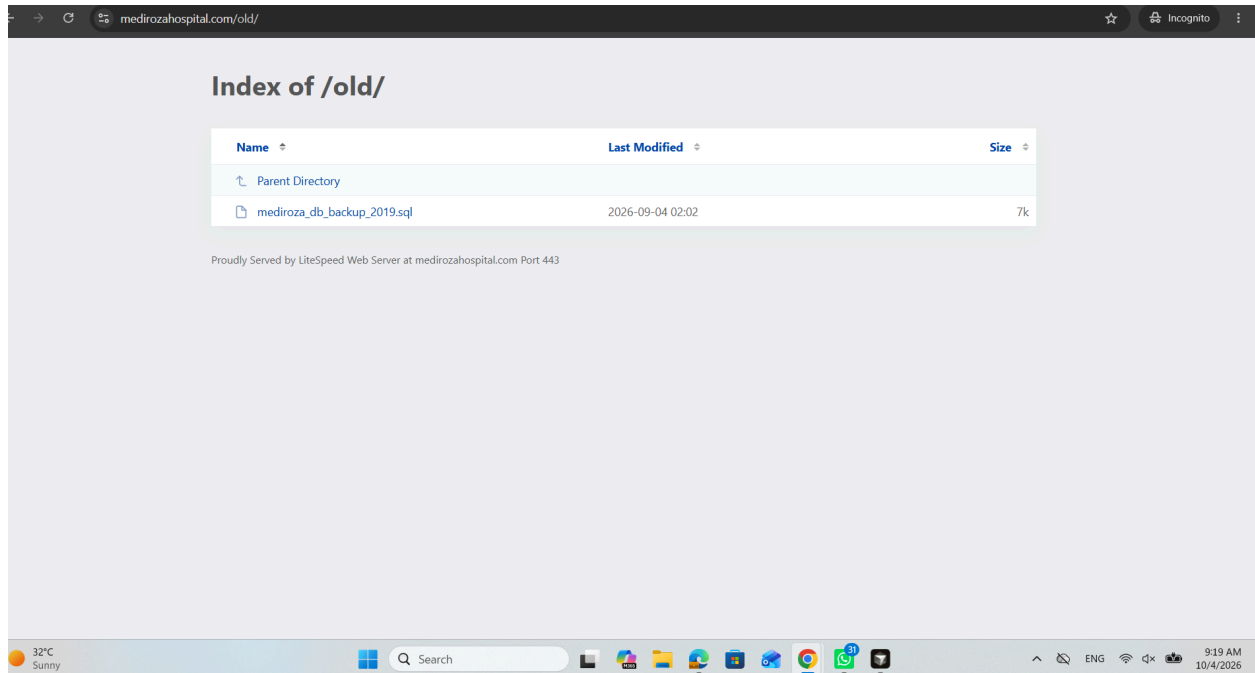


Figure: Directory Listing of /old/ and SQL Backup File

5. Risk Rating Summary

Finding ID	Vulnerability Description	Location	Risk Level	Exploited
F-01	SQL Injection Authentication Bypass	/patient/login.php	Critical	Yes
F-02	Weak PDF Document Passwords	Patient Reports	High	Yes
F-03	Sensitive PDF Metadata Disclosure	patient_report_3.pdf	Medium	Yes
F-04	Public Database Backup Exposure	/old/	Critical	Yes

6. Recommendations and Remediation

- **SQL Injection:** Rewrite authentication logic to use parameterized queries and prepared statements rather than raw string concatenation. Suppress verbose database error messages from returning to client interfaces.
- **Document Security:** Ensure sensitive medical records are stored behind robust portal access controls rather than relying solely on weak, easily crackable client-side PDF document

passwords.

- **Metadata Sanitization:** Strip all identifying internal metadata (authors, comments, operational notes) from released documents prior to distribution using tools like exiftool -all=.
- **Directory & Backup Hygiene:** Immediately remove backup archives from web-accessible directories, enforce strict file-system permissions, and disable directory indexing across all web servers.